2025 YES24 랜섬웨어 사례 분석

소프트웨어학부 | 이수아

©Saebyeol Yu. Saebyeol's PowerPoint

목차 A table of contents

1 기업 소개

2 기업 보안사고 조사

3 기업 보안사고 발생 배경

4 공격 기법

5 피해 규모

6 기술적/관리적/물리적 취약점

7 사고와 관련된 주요 보안기술 및 시스템 분석

8 보안정책 및 대응 체계 평가

9 사고 이후 개선된 보안정책 및 시스템

10 향후 유사사고 예방을 위한 제안

©Saebyeol Yu. Saebyeol's PowerPoint

1 기업 소개

기업명 : YES24

주요 사업 : 온라인 도서, eBook, 음반, 티켓 예매 등 유통 및 판매

©Saebyeol Yu. Saebyeol's PowerPoint

2 기업 보안사고 조사

2025.06.09

랜섬웨어 사건 발생

YES24 홈페이지, 모바일 앱, eBook 등 주요 서비스 마비

2025.06.10

랜섬웨어 해킹 사실 인정

2025.06.12

개인정보 유출 정황 공지

2025.06.13

도서·음반·DVD 등 중요 기능 1차 복구

2025.06.19

전체 서비스 복구

2025.08.11

랜섬웨어 사건 재발생

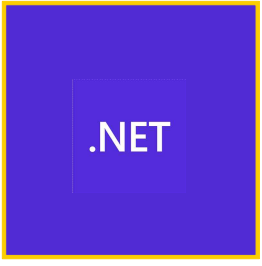
2025.08.11

7시간 내 전체 서비스 복구

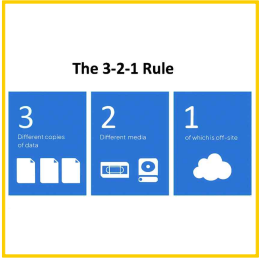
ⓒSaebyeol Yu. Saebyeol's PowerPoint

3 기업 보안사고 발생 배경

만료된 OS 사용



구식 개발 환경 유지



백업 미흡

©Saebyeol Yu. Saebyeol's PowerPoint

4 공격 기법

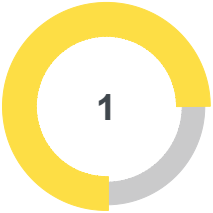
[Ransomare]

: 사용자의 파일을 암호화하거나 시스템을 사용하지 못하게 하여,
복호화의 대가로 금전을 요구하는 악성코드

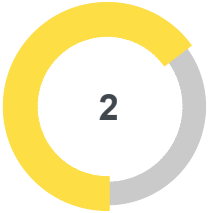
가용성 > 무결성 > 기밀성

©Saebyeol Yu. Saebyeol's PowerPoint

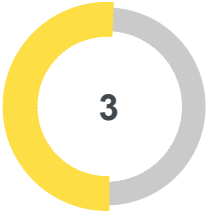
5 피해규모



5-11일동안 서비스 중단



브랜드 이미지 신뢰도 하락



재무적 손실

ⓒSaebyeol Yu. Saebyeol's PowerPoint

YES 24 재무제표

Financial Highlight [별도|전체]

단위 : 억원, %, 배, 천주 연결 별도 전체 연간 분기

IFRS(별도)	Annual				Net Quarter			
	2022/12	2023/12	2024/12	2025/12(E)	2025/03	2025/06	2025/09	2025/12(E)
매출액	6,468	6,419	6,558		1,774	1,359	1,498	
영업이익	167	91	185		73	-34	12	
영업이익(발표기준)	167	91	185		73	-34	12	
당기순이익	47	-41	16		70	-56	-42	

©Saebyeol Yu. Saebyeol's PowerPoint

6 기술적/관리적/물리적 취약점

기술적

- 만료된 구버전 OS
- 패치 미적용
- 미흡한 백업 구조
- 서버 접근 통제 부재

관리적

- 초기 대응 지연
- 해킹 사실 은폐
- 정부 및 보안 전문 기관 지원 거부

물리적

- 오프사이트 백업 부재
- 백업 장비 분리 미흡

사후 관리

- 동일 공격이 2개월 만에 재발생

©Saebyeol Yu. Saebyeol's PowerPoint

7 사고와 관련된 주요 보안 기술 및 시스템분석

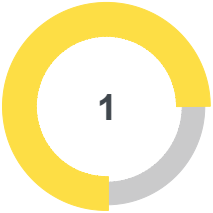
백업 >> 문서, 시스템 등의 중요 데이터의 손실, 손상, 재난 발생을 대비해 복사본을 만들어 별도의 안전한 장소에 저장하는 행위

시스템 >> 지원 종료된 Windows

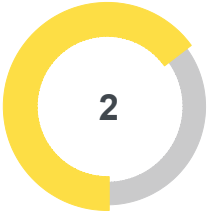
윈도우 2012는 마이크로소프트가 2023년 10월 기술 지원을 종료한 OS이다.
따라서, 공식적인 보안 패치 업데이트 지원을 받을 수 없다.

ⓒSaebyeol Yu. Saebyeol's PowerPoint

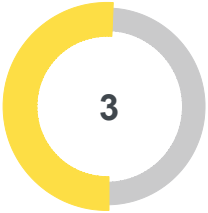
8 보안 정책 및 대응 체계 평가



보안 정책의 부재 혹은 실효성 부족



취약점 진단의 유무



투명성 부족 및 지원 회피

ⓒSaebyeol Yu. Saebyeol's PowerPoint

8 보안 정책 및 대응 체계 평가

탐지

- 1차: 사전 탐지 및 대응 실패
- 2차: 1차 대비 비교적 빠른 탐지 및 대응

분석

- 1차: 원인 분석 결과 투명성 부족
- 2차: 원인 공개 및 분석 결과 신속한 침투 경로 파악 못함

대응

- 1차: 서비스 장애를 가장한 사고 은폐 및 정부와 보안기관의 지원 거부
- 2차: 전사적 비상 대응 체계를 가동, 정부 및 외부 보안 전문 인력 투입

복구

- 1차: 서비스 정상화까지 장기간 소요
- 2차: 약 7시간 내 서비스 정상화

©Saebyeol Yu. Saebyeol's PowerPoint

9 사고 이후 개선된 보안 정책 및 시스템

기술

1. **백업 체계 개선**:
   2차 사고 당시 7시간 내 복구 성공
2. **시스템 업그레이드**:
   노후화된 시스템 전환 계획을 발표

관리

1. 외부 보안 자문 및 전문 인력 투입

정책

1. **사고 후 신속한 피해 사실 공지**
2. **대응 체계 가동**

©Saebyeol Yu. Saebyeol's PowerPoint

10 향후 유사 사고 예방을 위한 제안

기술

1. 모니터링 시스템
2. OS 개선 시 코드 리뷰
3. 관리자 권한에서 외부 IP 접속 시 차단

관리

1. 정기적 외부 보안감사
2. 보안 로그 모니터링 체계화

정책

1. 관리자 권한 관리 정책
2. 재발 방지 정책 마련

ⓒSaebyeol Yu. Saebyeol's PowerPoint

감사합니다

©Saebyeol Yu. Saebyeol's PowerPoint